# Inteligencia Artificial Ofensiva: Una Revisión de la Literatura

Oct 15, 2026 · @Legion Claude

*Daniel Mauricio Otero Vicente, Facultad de Ingeniería Industrial y de Sistemas (FIIS), Universidad Nacional de Ingeniería, Lima, Perú*

**Resumen—** La inteligencia artificial (IA) ofensiva, entendida como el uso de IA para atacar organizaciones y personas y como el conjunto de ataques dirigidos contra los propios sistemas de IA, pasó de ser una hipótesis a una realidad operativa en pocos años. Este artículo revisa diez trabajos de acceso abierto publicados entre 2020 y 2026: una taxonomía de amenazas, tres estudios de ataques a modelos de lenguaje de gran tamaño (LLM), cuatro trabajos sobre el uso de LLM como herramienta de ataque, un marco de evaluación de capacidades y un informe sobre una campaña de espionaje orquestada por IA. La literatura se organiza en dos ejes: ataques contra la IA y ataques con IA. Los resultados indican que los LLM memorizan y filtran datos de entrenamiento y pueden ser manipulados mediante inyección indirecta de instrucciones y sufijos adversarios. También indican que agentes basados en LLM explotan vulnerabilidades web y de un día, igualan a expertos humanos en phishing dirigido y, según el informe de su proveedor, ejecutaron entre 80% y 90% de una campaña de intrusión. Se discuten las limitaciones de la evidencia, las defensas disponibles y las líneas de trabajo futuro.

**Términos de indexación—** Inteligencia artificial ofensiva, ciberseguridad, aprendizaje automático adversario, modelos de lenguaje de gran tamaño (LLM), pruebas de penetración, ingeniería social, agentes autónomos.

## I. Introducción

Durante décadas, los ataques informáticos contra organizaciones dependieron del esfuerzo manual de atacantes con experiencia. La inteligencia artificial (IA) cambia ese panorama: los mismos avances que automatizan la predicción, la recuperación de información y la síntesis de medios permiten a un adversario ampliar y mejorar sus campañas [1]. Esta idea se conoce como IA ofensiva y abarca dos formas: usar IA para potenciar un ataque y atacar a los propios sistemas de IA [1].

La aparición de agentes basados en modelos de lenguaje de gran tamaño (LLM), capaces de usar herramientas, leer documentos y encadenar acciones, acelera este proceso. Lo que en 2021 era una proyección hoy cuenta con demostraciones experimentales y con incidentes documentados.

Este artículo revisa diez estudios de acceso abierto [1]–[10], complementados con tres fuentes sobre casos reales [11]–[13] y una referencia de normalización [14]. Sus aportes son tres:

- Una taxonomía de dos ejes (ataques contra la IA y ataques con IA) para ordenar la literatura.
- Una síntesis de los resultados cuantitativos de cada trabajo.
- Una discusión de las limitaciones de la evidencia y de las defensas disponibles.

Los trabajos se seleccionaron de forma intencional, por su relevancia, su cobertura de distintas modalidades de ataque y su acceso gratuito (arXiv, USENIX, ICLR y sitios institucionales). No se trata de una revisión sistemática, de modo que las conclusiones ofrecen un panorama y no una medición exhaustiva del campo. El resto del artículo se organiza así: la Sección II presenta el marco conceptual, las Secciones III y IV revisan los ataques contra la IA y con IA, la Sección V trata la evaluación de capacidades, la Sección VI describe casos reales, la Sección VII discute los hallazgos y la Sección VIII concluye.

## II. Marco conceptual y taxonomía

Mirsky et al. distinguen dos formas de IA ofensiva: atacar usando IA, para mejorar la eficiencia de un ataque (recopilación de información, automatización, descubrimiento de vulnerabilidades), y atacar a la IA, que explota los productos de IA del defensor y se conoce como aprendizaje automático adversario [1]. Para las organizaciones, identifican tres motivaciones del atacante: cobertura, velocidad y éxito [1].

Tomando como guía la matriz MITRE ATT&CK, el mismo trabajo cataloga 33 capacidades ofensivas en siete categorías: automatización, resiliencia de campañas, robo de credenciales, desarrollo de exploits, recopilación de información, ingeniería social y sigilo; la versión publicada en revista reporta 32 capacidades [1]. En el aprendizaje automático adversario, el atacante puede modificar los datos de entrenamiento, los datos de prueba, el código de entrenamiento o los parámetros del modelo, o bien analizar sus respuestas, con conocimiento total, parcial o nulo del sistema (caja blanca, gris o negra) [1].

La Tabla I resume la taxonomía que organiza este artículo.

**Tabla I. Taxonomía adoptada**

| Eje | Descripción | Trabajos revisados | Sección |
|---|---|---|---|
| Ataques contra la IA | El sistema de IA es el objetivo del ataque | Extracción de datos [2]; inyección indirecta de instrucciones [3]; sufijos adversarios [4] | III |

| Eje | Descripción | Trabajos revisados | Sección |
|---|---|---|---|
| Ataques con IA | La IA es la herramienta del atacante | Pentesting asistido [5]; hackeo web [6]; exploits de un día [7]; phishing dirigido [8] | IV |
| Medición y casos reales | Evaluación de capacidades e incidentes documentados | Cybench [9]; campañas e incidentes [10]–[13] | V–VI |

# III. Ataques contra sistemas de IA

## A. Extracción de datos de entrenamiento

Carlini et al. demuestran que un adversario con acceso de caja negra, es decir, que solo envía consultas y observa respuestas, puede recuperar ejemplos individuales del entrenamiento de un LLM [2]. Definen la memorización eidética: una cadena está memorizada si el modelo puede reproducirla y aparece en pocos documentos de entrenamiento [2]. El ataque tiene dos pasos: generar una gran cantidad de texto con el modelo y ordenar las muestras con métricas que comparan la probabilidad asignada por el modelo con la de una referencia, como un modelo más pequeño o un compresor zlib [2].

Sobre GPT-2, cuyos datos de entrenamiento son públicos, identificaron 604 secuencias memorizadas entre 1,800 candidatos revisados [2]. Entre ellas había nombres, teléfonos, correos y direcciones de personas, código y cadenas aleatorias como UUID, algunas contenidas en un solo documento [2]. Los modelos más grandes memorizan más: en el enfoque más difícil, el modelo de 1,500 millones de parámetros reprodujo todas las URL insertadas 33 veces o más, mientras el de 117 millones no reprodujo ninguna [2]. La memorización no requiere sobreajuste. Los autores proponen como mitigaciones la privacidad diferencial, la curación y deduplicación de datos y la auditoría de modelos, todas con limitaciones [2].

## B. Inyección indirecta de instrucciones

Greshake et al. muestran que las aplicaciones integradas con LLM son vulnerables a ataques remotos, sin interfaz directa con el atacante: este inserta instrucciones en datos que la aplicación recuperará después, como una página web o un documento [3]. La diferencia con la inyección directa es que el atacante no escribe en la consulta del usuario, sino en el contenido que el modelo procesa [3]. Los autores demostraron exploits sobre aplicaciones reales, incluida una integración de Bing Chat, con escenarios como la exfiltración de información del usuario, la desinformación, la inutilización de funciones y la propagación de la inyección a otros sistemas [3].

### C. Sufijos adversarios universales

Zou et al. proponen un método automático que encuentra una secuencia de caracteres que, añadida a una consulta, lleva a un modelo alineado a generar contenido objetable [4]. Los sufijos se optimizan contra varios modelos abiertos más pequeños y resultan universales, porque sirven para múltiples consultas, y transferibles, porque también funcionan contra LLM comerciales de caja negra [4]. Los autores advierten que un modelo alineado no es necesariamente robusto frente a estos ataques, un problema que la visión por computador arrastra desde hace una década y que podría ser inherente al aprendizaje profundo [4].

## IV. La IA como herramienta de ataque

### A. Pentesting asistido por LLM

Deng et al. evaluaron GPT-3.5, GPT-4 y Bard en pruebas de penetración y hallaron que los LLM son competentes en subtareas, como usar herramientas, interpretar su salida y proponer los siguientes pasos, pero pierden el contexto global de la prueba [5]. Para resolverlo propusieron PentestGPT, con tres módulos que interactúan entre sí: razonamiento, generación y análisis de datos (parsing) [5]. La herramienta mejoró en 228.6% la finalización de tareas frente a GPT-3.5 en los objetivos de referencia y también resolvió objetivos reales y desafíos CTF [5]. Los autores reconocen áreas donde los humanos aún superan a la tecnología [5].

### B. Agentes que hackean sitios web

Fang et al. dotaron a agentes LLM de lectura de documentos, llamadas a funciones y acceso a un navegador, y mostraron que pueden atacar sitios web de forma autónoma, con tareas como la extracción ciega del esquema de una base de datos y las inyecciones SQL, sin conocer de antemano la vulnerabilidad [6]. El mejor agente, basado en GPT-4, explotó 73.3% (11 de 15, pass@5) de las vulnerabilidades de prueba, y los modelos abiertos evaluados no lo lograron [6]. Además, GPT-4 encontró vulnerabilidades en sitios reales [6]. Según el análisis de costos de los autores, atacar así puede ser más económico que contratar a un probador de penetración [6].

### C. Explotación de vulnerabilidades de un día

Los mismos autores ampliaron el estudio a 15 vulnerabilidades reales de un día, es decir, divulgadas pero aún sin parchear [7]. Con la descripción del CVE, el agente basado en GPT-4 explotó 87%, mientras que todos los demás modelos y los escáneres abiertos ZAP

y Metasploit lograron 0% [7]. Sin la descripción, GPT-4 explotó solo 7% [7]. Esto sugiere que el retraso en aplicar parches se vuelve más costoso cuando la explotación de un CVE publicado puede automatizarse.

### D. Phishing dirigido automatizado

Heiding et al. compararon correos de phishing dirigido con 101 participantes en cuatro grupos [8]. La tasa de clics fue 12% en el grupo de control, 54% con correos de expertos humanos, 54% con correos totalmente automatizados por IA y 56% con IA asistida por un humano [8]. La herramienta automatizaba todo el proceso, incluida la recopilación de información y la creación de un perfil de vulnerabilidad de cada objetivo, y los perfiles resultaron precisos y útiles en 88% de los casos [8]. Los autores también probaron la defensa: Claude 3.5 Sonnet detectó la intención de los correos con más de 90% de acierto, y la versión publicada reporta 97.25% sobre 381 correos [8]. Por último, estiman que la IA puede aumentar la rentabilidad del phishing hasta 50 veces en campañas grandes [8].

## V. Evaluación de capacidades ofensivas

Medir lo que un agente puede hacer es un requisito para gestionar el riesgo. Cybench, de Zhang et al., es un marco para especificar tareas de ciberseguridad y evaluar agentes en ellas [9]. Incluye 40 tareas de captura de bandera (CTF) de nivel profesional, tomadas de cuatro competencias recientes, cada una con su descripción, sus archivos iniciales y un entorno donde el agente ejecuta comandos y observa los resultados [9]. Como muchas tareas exceden a los agentes actuales, los autores las dividen en subtareas que permiten una evaluación más fina [9].

Se evaluaron ocho modelos: GPT-4o, OpenAI o1-preview, Claude 3 Opus, Claude 3.5 Sonnet, Mixtral 8x22b Instruct, Gemini 1.5 Pro, Llama 3 70B Chat y Llama 3.1 405B Instruct [9]. Todos tuvieron dificultades con las tareas más difíciles, y la guía por subtareas produjo una tasa de éxito 3.2% mayor en tareas completas [9]. El código y los datos son públicos, con el argumento de que liberar el marco ayuda a medir y a mitigar el riesgo de nuevos modelos [9]. Frente a los trabajos de la Sección IV, Cybench aporta una medición comparable entre modelos y tareas, no la demostración de un ataque puntual.

# VI. Incidentes y herramientas en el mundo real

## A. Espionaje orquestado por IA (GTG-1002)

Anthropic detectó a mediados de septiembre de 2025 una operación de ciberespionaje que describe como el primer caso documentado de un ciberataque a gran escala ejecutado sin intervención humana sustancial [10]. El informe la atribuye con alta confianza a un actor patrocinado por el Estado chino, identificado como GTG-1002 [10]. Los atacantes construyeron un marco que usaba Claude Code y el protocolo MCP como herramienta automatizada de operaciones, con sub-agentes para tareas como mapear el ataque, escanear la infraestructura, buscar vulnerabilidades e investigar técnicas de explotación [10]. Para eludir las salvaguardas, presentaron las tareas como solicitudes técnicas rutinarias con roles predefinidos, de modo que cada pieza se ejecutaba sin el contexto malicioso completo [10].

Según el informe, la IA realizó entre 80% y 90% de la campaña, y se requirieron solo entre 4 y 6 puntos de decisión humana por campaña [10]. Se atacaron unas 30 organizaciones, con éxito en algunos casos [10]. El mismo informe reconoce que Claude alucinó y exageró o falseó resultados durante la operación autónoma, un obstáculo para los ataques totalmente autónomos [10]. Por provenir del propio proveedor del modelo, el informe debe leerse con cautela: en las fuentes revisadas no se encontró una verificación independiente, y algunos analistas han señalado la ausencia de indicadores técnicos verificables.

## B. Xanthorox AI

Xanthorox AI es una plataforma de IA criminal detectada a inicios de 2025 en foros de la darknet y canales cifrados, promocionada como sucesora de WormGPT y EvilGPT [11]. A diferencia de esas herramientas, que se apoyaban en jailbreaks o en la modificación de modelos existentes, se presenta como un sistema autónomo, modular y autoalojado, con modelos especializados (Coder, Vision y Reasoner, además de interacción por voz y búsqueda web) [11]. Las capacidades descritas provienen en buena medida del propio vendedor [11]. Algunos expertos advierten que su efectividad real no está comprobada y que podría estar exagerada por el marketing de su creador [13]. Su relevancia está en lo que representa: la comercialización y normalización de herramientas de IA diseñadas para el cibercrimen [13].

## C. Extorsión de datos asistida (GTG-2002)

El informe de amenazas de Anthropic de agosto de 2025 describe a un ciberdelincuente que usó Claude Code para automatizar el reconocimiento, la recolección de credenciales y la penetración de redes en una operación de extorsión de datos [12]. La campaña afectó

potencialmente a al menos 17 organizaciones en un mes, en gobierno, salud, servicios de emergencia e instituciones religiosas [12]. El actor empezó escaneando miles de endpoints VPN para hallar objetivos vulnerables y dejó sus tácticas preferidas en un archivo CLAUDE.md, que Claude Code usa como guía de comportamiento [12]. Anthropic lo calificó como una nueva evolución: los atacantes usan la IA para ejecutar ataques y no solo para facilitarlos [12]. El caso GTG-1002 fue una escalada posterior, porque en las operaciones de agosto los humanos seguían dirigiendo el proceso [10].

# VII. Discusión y defensas

## A. Síntesis comparativa

La Tabla II resume los diez trabajos revisados.

**Tabla II. Resumen de los trabajos revisados**

| Ref. | Año | Eje | Aporte | Resultado clave |
|---|---|---|---|---|
| [1] | 2021 (pub. 2023) | Taxonomía | Encuesta de capacidades ofensivas | 33 capacidades; suplantación, spear phishing y robo de modelos entre las mayores amenazas |
| [2] | 2020 (USENIX 2021) | Contra la IA | Extracción de datos de entrenamiento | 604 secuencias memorizadas en GPT-2 |
| [3] | 2023 | Contra la IA | Inyección indirecta de instrucciones | Compromiso remoto de aplicaciones con LLM, incluido Bing Chat |
| [4] | 2023 | Contra la IA | Sufijos adversarios | Ataques universales y transferibles a LLM de caja negra |
| [5] | 2023 (USENIX 2024) | Con IA | PentestGPT | 228.6% más tareas completadas que GPT-3.5 |
| [6] | 2024 | Con IA | Hackeo web autónomo | 73.3% de las vulnerabilidades explotadas (GPT-4) |
| [7] | 2024 | Con IA | Vulnerabilidades de un día | 87% con la descripción del CVE; 7% sin ella |

| Ref. | Año | Eje | Aporte | Resultado clave |
|---|---|---|---|---|
| [8] | 2024 (pub. 2026) | Con IA | Phishing dirigido automatizado | 54% de clics, igual que expertos humanos (control: 12%) |
| [9] | 2024 (ICLR 2025) | Medición | Cybench | 40 tareas CTF; 8 modelos evaluados |
| [10] | 2025 | Caso real | Campaña de espionaje | 80% a 90% de la campaña ejecutada por IA |

## B. Hallazgos transversales

Primero, la proyección de 2021 fue superada en parte. Mirsky et al. esperaban incidentes de IA ofensiva sobre todo al inicio y al final de la cadena de ataque, y consideraban improbable en el corto plazo que bots autónomos interactuaran con sistemas complejos, como la red de una organización [1]. Los agentes de [6], [7] y [10] muestran avances en esa dirección, aunque en condiciones de laboratorio o reportados por un proveedor.

Segundo, la ingeniería social es el vector más maduro. Los expertos consultados en [1] ubicaron la suplantación y el spear phishing entre las tres mayores amenazas, y [8] verificó con participantes humanos que el phishing automatizado iguala al de expertos humanos.

Tercero, la evidencia tiene límites. El estudio [6] se hizo sobre sitios de prueba aislados; el agente de [7] depende de la descripción del CVE para rendir bien; [8] se basa en 101 participantes; [9] muestra que los modelos fallan en las tareas más difíciles; y [10] es un informe del proveedor en el que los agentes alucinaron resultados. La efectividad real de Xanthorox, por su parte, no está comprobada [13].

Cuarto, las técnicas son de doble uso. [5] y [9] se presentan como apoyo a las pruebas de penetración y a la medición del riesgo, [8] probó un LLM como detector de phishing, y [1] advierte que las soluciones defensivas pueden convertirse en armas ofensivas.

## C. Defensas

El informe NIST AI 100-2e2025 [14] ofrece una taxonomía y una terminología comunes para los ataques contra IA predictiva y generativa, con sus mitigaciones y límites, y señala que no existe una defensa infalible. A partir de los trabajos revisados, se derivan las siguientes líneas de acción para las organizaciones, como recomendaciones del autor:

- Parchear con rapidez: [7] muestra que las vulnerabilidades publicadas y sin parchear pueden explotarse de forma automatizada.

- Verificar por canales alternos las solicitudes urgentes de dinero o datos y capacitar al personal: [1] y [8] muestran la eficacia de la suplantación y del phishing automatizado.
- Monitorear el comportamiento y el ritmo de las acciones, ya que los agentes operan a una velocidad y una escala que un humano no alcanza [1], [10].
- Proteger los datos de entrenamiento y tratar como no confiable el contenido que los LLM recuperan: [2] propone curar y deduplicar los datos y [3] muestra el riesgo de las integraciones con datos externos.
- Usar IA en la defensa, por ejemplo para detectar phishing [8], y auditar los modelos propios con marcos de evaluación [2], [9].

## VIII. Conclusiones

La literatura revisada muestra que la IA ofensiva tiene dos caras. Los modelos de IA son un objetivo con vulnerabilidades propias, como la memorización de datos [2], la inyección de instrucciones [3] y los sufijos adversarios [4]. A la vez, la IA es una herramienta que reduce el costo y el conocimiento necesarios para atacar [5]–[8]. Los experimentos controlados indican que los agentes LLM ya explotan vulnerabilidades reales [6], [7] y que el phishing automatizado iguala al de expertos humanos [8], mientras que los informes de proveedores describen campañas en las que la IA ejecuta la mayor parte del trabajo técnico [10], [12].

Al mismo tiempo, la evidencia es desigual: abundan los resultados de laboratorio, los informes provienen en parte de los propios proveedores y herramientas criminales como Xanthorox se conocen sobre todo por su publicidad. Como trabajo futuro se proponen una revisión sistemática con criterios de inclusión explícitos, la reproducción de los experimentos con modelos más recientes y la medición de defensas basadas en IA frente a ataques automatizados.

## Referencias

[1] Y. Mirsky *et al.*, "The threat of offensive AI to organizations," *Comput. Secur.*, vol. 124, 2023, arXiv:2106.15764. [En línea]. Disponible: https://arxiv.org/abs/2106.15764

[2] N. Carlini *et al.*, "Extracting training data from large language models," in *Proc. USENIX Security Symp.*, 2021, arXiv:2012.07805. [En línea]. Disponible: https://arxiv.org/abs/2012.07805

[3] K. Greshake, S. Abdelnabi, S. Mishra, C. Endres, T. Holz, and M. Fritz, "Not what you've signed up for: Compromising real-world LLM-integrated applications with indirect prompt injection," arXiv:2302.12173, 2023. [En línea]. Disponible: https://arxiv.org/abs/2302.12173

[4] A. Zou, Z. Wang, N. Carlini, M. Nasr, J. Z. Kolter, and M. Fredrikson, "Universal and transferable adversarial attacks on aligned language models," arXiv:2307.15043, 2023. [En línea]. Disponible: https://arxiv.org/abs/2307.15043

[5] G. Deng *et al.*, "PentestGPT: Evaluating and harnessing large language models for automated penetration testing," in *Proc. 33rd USENIX Security Symp.*, 2024, arXiv:2308.06782. [En línea]. Disponible: https://arxiv.org/abs/2308.06782

[6] R. Fang, R. Bindu, A. Gupta, Q. Zhan, and D. Kang, "LLM agents can autonomously hack websites," arXiv:2402.06664, 2024. [En línea]. Disponible: https://arxiv.org/abs/2402.06664

[7] R. Fang, R. Bindu, A. Gupta, and D. Kang, "LLM agents can autonomously exploit one-day vulnerabilities," arXiv:2404.08144, 2024. [En línea]. Disponible: https://arxiv.org/abs/2404.08144

[8] F. Heiding, S. Lermen, A. Kao, B. Schneier, and A. Vishwanath, "Evaluating large language models' capability to launch fully automated spear phishing campaigns: Validated on human subjects," arXiv:2412.00586, 2024. Versión publicada: "Evaluating large language models' ability to automate spear phishing," *Expert Syst. Appl.*, vol. 314, Art. 131546, jun. 2026. [En línea]. Disponible: https://arxiv.org/abs/2412.00586

[9] A. K. Zhang *et al.*, "Cybench: A framework for evaluating cybersecurity capabilities and risks of language models," in *Proc. Int. Conf. Learn. Represent. (ICLR)*, 2025, arXiv:2408.08926. [En línea]. Disponible: https://arxiv.org/abs/2408.08926

[10] Anthropic, "Disrupting the first reported AI-orchestrated cyber espionage campaign," nov. 2025. [En línea]. Disponible: https://assets.anthropic.com/m/ec212e6566a0d47/original/Disrupting-the-first-reported-AI-orchestrated-cyber-espionage-campaign.pdf. Consultado: 15 oct. 2026.

[11] SlashNext, "Xanthorox AI – The next generation of malicious AI threats emerges," *Security Boulevard*, abr. 2025. [En línea]. Disponible: https://securityboulevard.com/2025/04/xanthorox-ai-the-next-generation-of-malicious-ai-threats-emerges/. Consultado: 15 oct. 2026.

[12] Anthropic, "Threat Intelligence Report: August 2025," ago. 2025. [En línea]. Disponible: https://www-cdn.anthropic.com/b2a76c6f6992465c09a6f2fce282f6c0cea8c200.pdf. Consultado: 15 oct. 2026.

[13] "Xanthorox – New BlackHat AI tool used to launch phishing & malware attacks," *Cyber Security News*. [En línea]. Disponible: https://cybersecuritynews.com/xanthorox-ai-blackhat-tool/amp/. Consultado: 15 oct. 2026.

[14] National Institute of Standards and Technology, "Adversarial machine learning: A taxonomy and terminology of attacks and mitigations," NIST AI 100-2e2025, Gaithersburg, MD, EE. UU., 2025, doi: 10.6028/NIST.AI.100-2e2025.